

AI Use Policy

A template for charity, cultural and heritage organisations

Free to use, free to adapt, and written to be argued with.

Last checked against UK law and ICO guidance on 25 August 2026

Jasmin Aziz

Strategic communications consultant

jasminaziz.co.uk · Shared through The Edit, theeditai.co.uk

How to use this

This is a working template, not a finished policy. It assumes you have no legal team, no IT department, and no appetite for a document nobody reads.

Fill in the square brackets. Delete what does not apply to you. Take it to your senior team, then your board. The point is to end up with something short enough that your staff will actually read it and specific enough that it changes what they do on Monday.

A policy PDF in a shared drive is not governance. Governance is a named person, a gate, and a data rule. This template gives you all three.

Expect it to take two meetings and an afternoon.

1. Why we have this policy

[ORGANISATION] uses AI tools in its work. Staff are already using them, whether or not we have written anything down. This policy exists so that use is deliberate rather than accidental, and so that the people responsible for this organisation can answer three questions with confidence:

- What AI tools are we using, and for what?
- What happens to the information we put into them?
- Who is accountable when something goes wrong?

This policy applies to everyone who works for or on behalf of [ORGANISATION], including staff, trustees, volunteers, freelancers and contractors.

2. What we mean by AI

This policy covers **generative AI tools**: systems that produce text, images, audio, video or code in response to a prompt. Claude, ChatGPT, Gemini and Copilot are the common ones. It also covers tools with AI built into them, such as meeting note-takers, transcription services and design tools with generative features.

Two terms are worth knowing, because the risk is different for each.

Conversational AI responds to what you type. It produces text or images. It takes no action of its own. You decide what to do with the output.

Agentic AI pursues a goal across several steps, using tools you have connected to it. It can send, book, file or publish. The output is an action, not a draft.

A **connector** is a permission you give an AI tool to reach another system you use: your inbox, your calendar, your files, your CRM. A connector inherits the access of the account you sign in with. If you connect it to your full work email, it can see everything you can see.

3. The five things this policy sets up

1. **An audit.** We know what is actually in use.
2. **A risk classification.** We know which uses are low risk and which are not.
3. **A named owner.** One person is accountable.
4. **A gate.** New tools get checked before they are adopted.
5. **Training.** People know what not to do, not just what to do.

The gate matters more than its complexity. A one-page check that actually happens beats a procurement process that gets skipped.

4. Who is responsible

[NAME / ROLE] is the AI lead for [ORGANISATION]. They are responsible for maintaining the tool register, running the gate on new tools, and reporting to [SENIOR TEAM / BOARD] on AI use [ANNUALLY / TWICE A YEAR].

This is not a technical role. It does not require the postholder to understand how the models work. It requires them to keep a list, ask the questions in section 8, and escalate what they cannot answer.

Every member of staff is responsible for the output they send. AI drafts. A person approves. That responsibility does not transfer to the tool.

The [BOARD / TRUSTEES] are responsible for satisfying themselves that this policy exists, is followed, and is reviewed. They are not responsible for approving individual tools.

5. What staff may and may not do

Five rules. They apply to everyone, every time.

One. Treat any AI tool as a system you do not control. Anything you put in is in. Anything it puts out is your responsibility.

Two. Personal data does not belong in a consumer AI tool. That means names, contact details, financial information, and anything about specific supporters, beneficiaries, service users, children, or colleagues. Some of it is special category data under Article 9 UK GDPR, which includes anything revealing health, religious belief, ethnicity, political opinion or sexual orientation, and that carries a higher bar than ordinary personal data. UK GDPR applies whether or not you remember it does. If you are unsure whether something counts as personal data, assume it does and ask [NAME / ROLE].

Three. Check before you send. Three questions, thirty seconds, every time you are about to act on AI output for anything that matters:

- Is there anything here I cannot personally verify?

- Does it contain a specific claim, a figure, a date, a name, an attribution, that I should check against the source?
- Would I put my name to this without a second read?

Four. A person approves anything that leaves the building. Drafts are AI work. Sent communications are human work, even when the AI wrote most of the words. This applies to anything reaching a supporter, a funder, a beneficiary, a journalist or the public.

Five. Some tasks are not for AI. See section 7.

6. What we use, and what we put into it

[ORGANISATION] maintains a register of approved AI tools. It lists, for each tool: what it is used for, who owns it, what plan we are on, where the data is held, and whether the provider trains on what we put in.

The register lives at [LOCATION] and is maintained by [NAME / ROLE].

Approved tools and approved uses

Tool	What it is for	Plan	May it receive personal data?
[TOOL]	[USE]	[PLAN]	[YES, under [CONDITIONS]] / NO]
[TOOL]	[USE]	[PLAN]	[YES, under [CONDITIONS]] / NO]

Where the data sits matters, and so does the plan. The same tool behaves differently on different tiers. Four positions, in order of how much you can rely on them:

- 1. Consumer plan with training switched off in settings.** Acceptable for low-sensitivity daily work: drafting from public material, rewording, summarising documents that contain no personal data. This relies on the toggle doing what it says and the provider's privacy policy matching it. That is not a safe assumption for anything involving identifiable people. A consumer plan also gives you no data processing agreement, and Article 28 UK GDPR requires a written contract before anyone processes personal data on your behalf. That, rather than the plan's name, is what separates this position from position three.
- 2. Paid individual plan.** Better terms, usually, but rarely a data processing agreement. Paying more is not the same as being covered. Read them. Do not assume.
- 3. Team or enterprise plan** with a data processing agreement in place. Appropriate for organisational drafting and internal workflows. Terms vary significantly between providers, so check the one you are signing.

4. **No AI tool at all.** The correct answer for some categories. See section 7.

If you do not know which position a tool sits in, it is not approved yet.

What happens to what we put in

A chat history is a record. Where it contains personal data, UK GDPR applies to it exactly as it applies to anything else we hold, including a subject access request.

Most tools keep conversations indefinitely unless told otherwise. For every tool in the register, [NAME / ROLE] records where history is stored, what retention the tool lets us set, and who can delete it.

- Set retention where the tool allows it. Where it does not, that counts against the tool at the gate.
- Delete a conversation when the work it supported is finished, unless there is a reason to keep it. Write the reason down.
- Deleting from the interface is not the same as deleting from the provider's systems. Check the provider's stated deletion window and record it.

Record these decisions in the retention schedule [ORGANISATION] already keeps rather than starting a second one. The register above is also most of a record-of-processing entry, so feed it into that rather than maintaining both.

7. Where AI does not belong

Some tasks are excluded not because the output would be worse, but because a person doing the work is the point.

This is a starting list. Delete what does not apply to [ORGANISATION] and add what does. The generic version is worth nothing. The version your staff argued about is worth a lot.

- Safeguarding: assessments, records, decisions and referrals.
- Pastoral and welfare conversations with staff, volunteers, service users or beneficiaries.
- Condolence and bereavement correspondence, including to the families of supporters.
- Apologies. When we have got something wrong, a person writes it.
- Individual correspondence where the relationship is the service: casework, advocacy, befriending, mentoring.
- Complaints responses addressed to a named person.
- Employment matters: references, disciplinary and grievance correspondence, redundancy communications.
- Writing in the voice of a beneficiary, service user or community member. Their testimony is theirs, and a plausible version of it is a fabrication.

- Writing about or on behalf of a community none of us belongs to. The tool will produce something that sounds right, and sounding right is the problem.
- Board papers where trustees are relying on the writer's own judgement of risk.
- Anything a named individual would reasonably expect a person wrote.

A supporter receiving a personalised letter that an AI generated and nobody read is receiving something different from a letter a person wrote, even when the words are identical.

8. The gate: adopting a new tool

Before [ORGANISATION] adopts any new AI tool, [NAME / ROLE] answers these questions on one page. If a question cannot be answered, the tool is not adopted.

1. **What is it for?** Name the job, not the category.
2. **Who will use it, and what will they put into it?**
3. **Where is the data held?** UK, EU, US, or unclear. If it sits outside the UK and personal data is involved, ask what transfer mechanism covers it.
4. **Does the provider train on what we put in?** On our plan specifically, not on their enterprise tier.
5. **Is there a written data processing agreement?** Article 28 UK GDPR requires one before a provider processes personal data on our behalf. Without it the tool is not approved for anything containing personal data, whatever else it clears.
6. **Is there a nonprofit or charity tier?** Many providers have one and do not advertise it.
7. **What can it do without a person approving?** If the answer is anything at all, see section 9.
8. **Is this likely to need a DPIA?** See section 12.
9. **Could we answer a subject access request from it?** We have to be able to search and export what people put in. If we cannot, we cannot answer a request from it, and we will find that out on the day one arrives.
10. **What happens if we stop using it?** Can we get our content out.

A tool that clears the gate goes into the register in section 6. A tool that does not is either declined or escalated to [SENIOR TEAM].

Nobody signs up to a new AI tool with an [ORGANISATION] email address without this check.

9. Agentic tools and connectors

Where a tool can take action rather than produce a draft, five additional questions apply before it is approved:

1. **What actions can it take?**
2. **What can it reach, and under whose account?** A connector inherits the access of whoever signs in. Name the mailbox, the folder, the record.
3. **Who reviews before it acts?**
4. **Are its actions logged, and who can see the log?** Without one there is no way to reconstruct what it did.
5. **What is the escalation path when it does something wrong?**

Two things change once a tool can act. Actions can be irreversible: you can ignore a bad draft, you cannot unsend a bad email. And failures can be silent: in a conversation you see every response, in an automated workflow the intermediate steps may never be seen by anyone.

Connectors are granted by [NAME / ROLE] and reviewed [QUARTERLY / TWICE A YEAR]. A connector is disconnected when the person who set it up changes role or leaves, or when the tool stops being used.

10. How people learn this

A training day on its own changes very little. What changes behaviour is knowing the rules on day one, learning each tool at the moment it arrives, and having somewhere to ask without feeling foolish.

It is also an accountability obligation. Articles 5(2), 24 and 32 UK GDPR require us to be able to show we took reasonable steps, and training is among the first things the ICO asks about after something goes wrong.

On joining. Everyone who works for or on behalf of [ORGANISATION] gets this policy and Appendix B in their first week. [NAME / ROLE] talks them through the two rules that carry the most weight: no personal data in a consumer tool, and a person approves anything that leaves the building.

When a tool joins the register. A new tool is the training moment. [NAME / ROLE] shows the people who'll use it what it's for, what must not go into it, and which settings we've configured. A tool nobody has been shown is a tool nobody uses safely.

Somewhere to ask. [NAME / ROLE] is the person to ask. Nobody here is treated as slow for checking whether something is allowed. The alternative is people guessing, and doing it quietly.

A check-in in the diary. [NAME / ROLE] reviews how AI is actually being used with [SENIOR TEAM] [QUARTERLY / TWICE A YEAR], and the next date goes in the diary before the current one finishes. This is where the register gets corrected against what people are really doing.

If you want more than this. A session works when it's built on your team's real tasks and the hard scenarios get argued out in the room. A general overview of what AI is does not. If [ORGANISATION] commissions training, commission the first kind.

11. Images, rights and attribution

AI-generated images carry two problems that text does not: who owns them, and who they appear to depict.

Ownership is unsettled. Section 9(3) of the Copyright, Designs and Patents Act 1988 makes the author of a computer-generated work the person who made the arrangements necessary for creating it. Whether that is the person typing the prompt has never been tested in a UK court, and the Government proposed removing the provision altogether in its Copyright and AI report of March 2026. So we may not own what we generate. [ORGANISATION] does not use AI-generated imagery where we need to own or exclusively licence the asset: [MAJOR CAMPAIGNS / MERCHANDISE / ANYTHING A FUNDER MAY REUSE].

Check the tier. Several tools grant commercial rights on paid plans only. A free account may not give us the right to use the output at all. [NAME / ROLE] confirms this at the gate and records it in the register.

People. We do not generate images of real, identifiable people without their consent, and we do not use AI-generated images of people in any way that implies they are our beneficiaries, supporters, volunteers or staff. A composite face in a fundraising appeal is a lie about who we serve.

Style. We do not generate work in the style of a named living artist or illustrator, and we do not use AI to replicate the work of anyone we have previously commissioned.

Supplied material. Photography, artwork and footage given to us by a funder, partner or photographer is theirs on their terms. It does not go into a tool that trains on input.

12. Data protection and DPIAs

A Data Protection Impact Assessment is a legal requirement under Article 35 UK GDPR for processing likely to result in a high risk to people's rights. AI processing of personal data will often meet that bar, because the ICO treats innovative technology as a trigger when it combines with any second risk factor, and this sector usually supplies one: special category data, vulnerable people, or processing those people cannot see. This is the law, not regulator guidance.

To be precise about what the requirement is: organisations carry out DPIAs. Tools do not have them and cannot provide them. The question is never whether a tool "has" a DPIA. It is whether your intended use of it triggers one. A provider can give you information for yours,

and under Article 28(3)(f) a processor has to help you with it, but that is not the same as the tool having one.

[ORGANISATION] will complete a DPIA before [any AI processing of supporter, beneficiary or service-user personal data / any use of an AI tool that takes action without human review / ADD YOUR OWN TRIGGERS].

Our data protection lead is [NAME / ROLE]. Where this policy and our data protection policy conflict, the data protection policy takes precedence.

[[ORGANISATION] is registered with the ICO under registration [NUMBER] / [ORGANISATION] is exempt from the data protection fee.] Check which applies rather than assuming: the ICO runs a not-for-profit exemption and many small charities qualify.

13. What we tell people

Openness is cheaper than being found out.

Staff. This policy is reissued to everyone whenever it is updated. People are accountable for using a tool they knew was not approved.

Trustees. [NAME / ROLE] reports on AI use [ANNUALLY / TWICE A YEAR], covering: what is in the register, what changed, anything that went wrong, and anything the board needs to decide.

Supporters, funders and the public. [ORGANISATION] [does / does not] disclose AI involvement in its communications. Where we do:

- We do not present AI-generated content as the personal writing of a named individual without that person having written or substantially edited it.
- [ADD YOUR POSITION ON DISCLOSURE IN FUNDING APPLICATIONS]

Funders increasingly ask. Have the answer before the question.

14. When something goes wrong

If AI output has caused or may cause harm, including an inaccuracy that reached someone outside the organisation, a personal data breach, or an automated action nobody intended:

1. Tell [NAME / ROLE] the same day. Do not wait to establish whether it is serious.
2. [NAME / ROLE] assesses whether it is a personal data breach. If it is, our data protection policy governs what happens next, including the 72-hour reporting window, which runs from when we became aware of the breach rather than from when it happened. Where the breach is likely to be a high risk to the people affected, Article 34 UK GDPR also requires us to tell them, without undue delay. The bar for telling people is higher than the bar for telling the regulator, and it is the harder conversation.

3. Where the incident is serious, [NAME / ROLE] reports it to [THE CHARITY COMMISSION / OSCR / CCNI] as a serious incident or notifiable event, alongside anything owed to the ICO. The three UK charity regulators run separate systems, so a charity registered in more than one nation reports to each.
4. [NAME / ROLE] records what happened and what changed as a result.

Reporting early is treated as good practice, not as an admission.

15. Review

This policy is reviewed [ANNUALLY] by [NAME / ROLE] and approved by [SENIOR TEAM / BOARD].

It is reviewed sooner if: a tool in the register materially changes its terms, a new category of use is proposed, an incident occurs, or the regulatory position changes.

The table below records [ORGANISATION]'s own policy versions. The date this template was last checked against UK law and ICO guidance is in the footer of every page. Adopting a newer template does not renumber your policy.

Your policy version	Date	Approved by	Changes
1.0	[DATE]	[NAME]	First adoption

If you get stuck

The parts of this template that need judgement are the ones you can't copy from anyone else: which tasks stay human, what triggers a DPIA in your organisation, and what you tell funders. If you're stuck on one of those, tell me where you've got to.

Jasmin Aziz

hello@jasminaziz.co.uk

Appendix A: The new tool check

One page. Copy it, fill it in, keep it with the register.

Tool: _____ **Date:** _____

Requested by: _____

Question	Answer
What is it for?	
Who will use it?	
What goes into it?	
Where is the data held?	
Does it train on our input, on our plan?	
Is there a written data processing agreement?	
Is there a charity or nonprofit tier?	
What can it do without approval?	
Does our use likely trigger a DPIA?	
Could we answer a subject access request from it?	
Can we get our content out if we leave?	

Decision: [Approved / Declined / Escalated]

Approved by: _____ **Review date:** _____

Appendix B: The check before you send

Print it. Stick it near the people who send things.

Before you act on any AI output that matters:

1. Is there anything here I cannot personally verify?
2. Does it contain a figure, date, name or attribution I should check against the source?
3. Would I put my name to this without a second read?

Three questions. Thirty seconds. It is the difference between the organisations that get caught out by AI and the ones that do not.

This template is provided as a starting point for charity, cultural and heritage organisations. It is not legal advice. Adapt it to your organisation, and take advice where your circumstances need it.

Written by Jasmin Aziz, strategic communications consultant.
jasminaziz.co.uk · Shared through [The Edit](https://theeditai.co.uk).